



PUBLIC PORTFOLIO SUMMARY

WPWN Vulnerability Assessment

สรุปผลงานการประเมินช่องโหว่ในสภาพแวดล้อมจำลอง
โดยเผยแพร่เฉพาะข้อมูลระดับสูงและแนวทางแก้ไขที่ปลอดภัย

ผู้จัดทำ	ดิณณภพ ออกกิจวัตร
บทบาท	Security Tester / Report Contributor
ขอบเขต	Authorized simulated laboratory

เอกสารฉบับนี้ตัด IP, credentials, ข้อมูลติดต่อ, หลักฐานเชิงรุก และข้อมูลสมาชิกในทีมออกทั้งหมด

ภาพรวมโครงการ

โครงการนี้เป็นการประเมินความมั่นคงปลอดภัยของเครื่อง WPWN ภายในห้องปฏิบัติการจำลองที่ได้รับอนุญาต เป้าหมายคือค้นหา จัดระดับ และรายงานช่องโหว่อย่างเป็นระบบ พร้อมเสนอแนวทางลดความเสี่ยงโดยอ้างอิง OWASP และหลักการ hardening ที่เหมาะสม

ส่วนที่รับผิดชอบ

01	ทดสอบและตรวจสอบช่องโหว่ตามขอบเขตที่ได้รับมอบหมาย
02	รวบรวมหลักฐานและตรวจสอบผลเพื่อลด false positive
03	จัดระดับความรุนแรงและผลกระทบของแต่ละประเด็น
04	จัดทำเนือหารายงานและข้อเสนอแนะในการแก้ไข

กระบวนการทำงาน

กำหนดขอบเขต → สืบหาบริการ → สแกนช่องโหว่ → ตรวจสอบผล → ประเมินความเสี่ยง → จัดทำรายงานและแนวทางแก้ไข

เครื่องมือและกรอบอ้างอิง

Nessus • OWASP • CVSS • Linux Security Tools • Security Documentation

สรุปผลการประเมิน

ตารางนี้เป็นข้อมูลสรุประดับ Portfolio ไม่ระบุ IP, hostname, credential, payload หรือขั้นตอน Proof of Concept

ช่องโหว่ของ WordPress plugin	Critical	อาจนำไปสู่การสั่งงานจากระยะไกลหากไม่ได้แก้ไข
การเปิดเผยข้อมูลรับรอง	High	เพิ่มความเสี่ยงต่อการเข้าถึงระบบโดยไม่ได้รับอนุญาต
การกำหนดสิทธิ์ไม่เหมาะสม	High	อาจทำให้ผู้ใช้ยกระดับสิทธิ์เกินความจำเป็น
SSH protocol weakness	Medium	ลดความมั่นคงของการเชื่อมต่อในบางเงื่อนไข
Directory listing	Low	เปิดเผยโครงสร้างไฟล์และข้อมูลที่ไม่ควรแสดง
Web server information disclosure	Low	ช่วยให้ผู้โจมตีระบุเทคโนโลยีและวางแผนโจมตีได้ง่ายขึ้น

สิ่งที่ได้เรียนรู้

ผลจากเครื่องมือสแกนต้องผ่านการตรวจสอบก่อนนำไปรายงาน และรายงานที่ดีควรอธิบายทั้งความเสี่ยง ผลกระทบ และวิธีแก้ไขในภาษาที่ผู้ดูแลระบบนำไปใช้งานต่อได้

แนวทางแก้ไข

ข้อเสนอแนะระดับสูงสำหรับลดความเสี่ยง โดยอ้างอิงหลัก secure configuration, least privilege และ OWASP

Patch management	อัปเดต WordPress, plugin และระบบปฏิบัติการอย่างสม่ำเสมอ พร้อมนำ component ที่ไม่ใช้งานออก
Secrets management	ไม่นำ credential ไว้ในไฟล์ที่เว็บเข้าถึงได้ หมุนเวียนรหัสผ่าน และใช้ secret storage ที่เหมาะสม
Least privilege	จำกัดสิทธิ์ sudo และสิทธิ์ของ service account ให้เท่าที่จำเป็น พร้อมทบทวนเป็นระยะ
Server hardening	ปิด directory listing ลดข้อมูล banner และตั้งค่า web server ตามแนวทาง secure configuration
Secure remote access	อัปเดต SSH ปิด algorithm ที่ล้าสมัย ใช้ key-based authentication และติดตาม login anomaly
Verification	สแกนและทดสอบซ้ำหลังแก้ไขเพื่อยืนยันว่าความเสี่ยงลดลงและไม่เกิด regression

PUBLICATION NOTE

เอกสารนี้จัดทำเพื่อแสดงทักษะใน Portfolio เท่านั้น ไม่ใช่รายงานฉบับเต็ม และไม่มีข้อมูลที่สามารถใช้ระบุเป้าหมายหรือทำซ้ำการโจมตีได้